SIZMA TESTİ RAPORU

Rapor Tarihi	06/08/2026
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. Blind OS command injection with time delays

Bu raporda PortSwigger Web Security Academy'de yer alan "Blind OS command injection with time delays" labı ele alınmıştır. Bu labda Burp Suite ve Burp Suite Repeater kullanılmıştır.

2. Yönetici Özeti

Yapılan test sonucunda, hedef uygulamanın feedback gönderme özelliğinde zafiyet bulunmuştur. Bu zafiyet, saldırganın hedef sunucuda keyfi sistem komutları çalıştırmasına ve sistemin tamamen ele geçirilmesine olanak tanımaktadır. Zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Feedback gönderme özelliğinde OS command injection zafiyeti barındırdığı söylenmektedir. Bu uygulamada bir shell çalıştırıldığında yanıt (response) dönmemekte veya geç dönmektedir. Çözüm için 10 saniyelik delay komutunun çalıştırması istenmektedir.

4. Risk Seviyesi

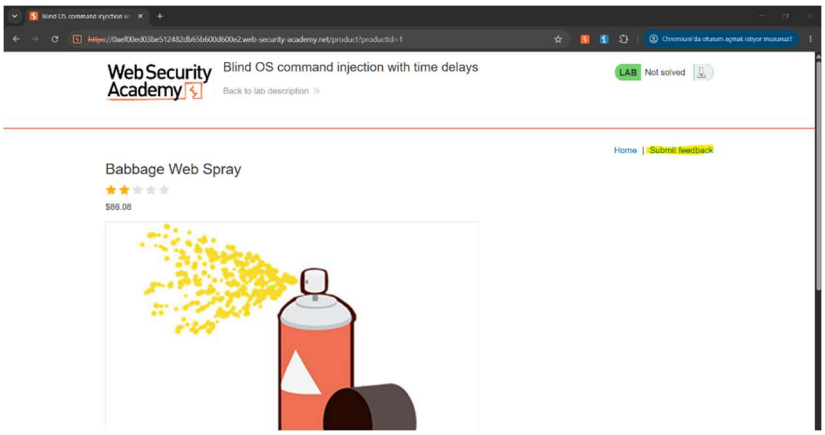
Risk Seviyesi	Kritik
CVSS v3.1 Skoru (ops.)	-
CWE (opsiyonel)	-

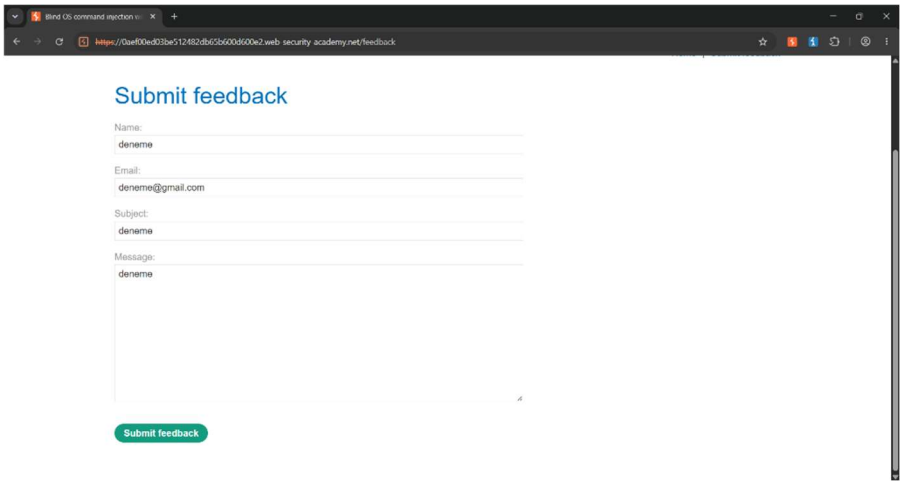
5. Etki

Saldırgan hedef sunucuda OS komutlarını çalıştırılabilir. Bu da sistemi tamamen ele geçirmekten hassas verilere erişime kadar çeşitli sorunlara sebebiyet verebilir.

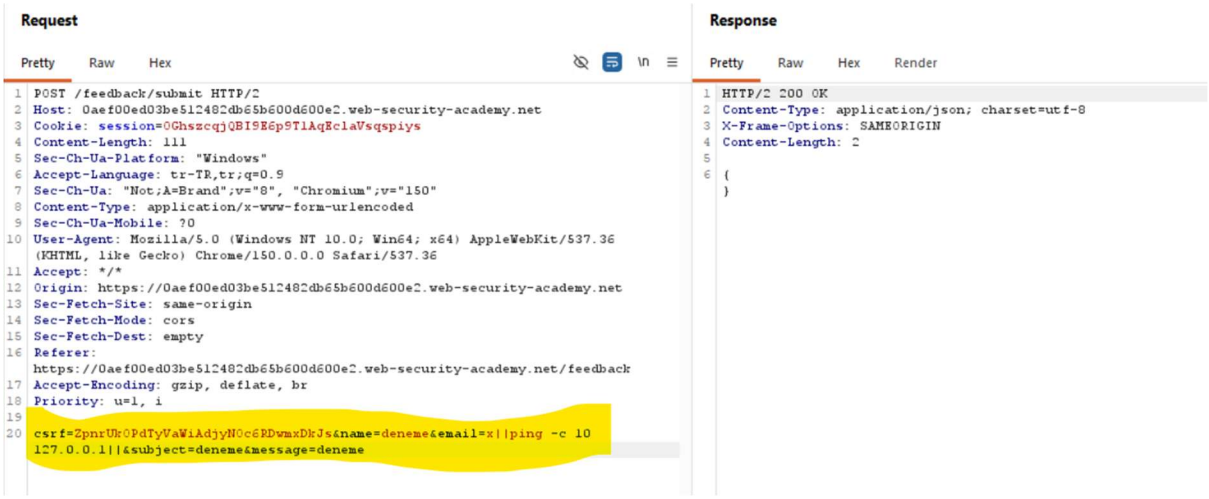
6. Proof Of Concept

İlk olarak ilgili siteye erişilmiştir. Zafiyetin feedback gönderme özelliğinde olduğu bilindiği için herhangi bir ürünün sayfasına girip burada yer alan "submit feedback" kısmına erişilmesi yeterlidir.





Deneme amaçlı feedback formu doldurup yollanır ve ilgili POST metodunda Burp Suite ile inceleme yapılır. İnceleme yapıldığında requestin en altında çeşitli parametreler gözükmektedir. Buradaki parametrelerde payload denenebilir.



Email paratmeresinde aşağıdaki payload denendiğinde response 10 saniye gecikir ve lab başarıyla çözülmüş olunur:
>email=x||ping -c 10 127.0.0.1||
Komut çıktısı doğrudan görülemediğinden, ping -c 10 komutu ile 10 saniyelik bir gecikme oluşturulmuştur. Yanıtın normalde anında gelmesine karşın 10 saniye gecikmesi, enjekte edilen komutun sunucuda çalıştırıldığını kanıtlamaktadır.

7. Çözüm Önerisi

Kullanıcı girdisi hiçbir zaman doğrudan sistem komutuna dahil edilmemelidir. Bunun yerine, dile özgü hazır API/kütüphane fonksiyonları kullanılmalıdır. Girdi, komuta bir string olarak birleştirilmek yerine, komut ile argümanları ayrı biçimde işleyen güvenli fonksiyonlarla aktarılmalıdır. Böylece girdi, komut olarak değil yalnızca veri olarak yorumlanır.

8.Sonuç

Testin sonucunda hedefin komut enjeksiyonuna açık olduğu doğrulanmıştır.